Progettazione e sviluppo di un Relying Party conforme allo standard EUDI Wallet

dal parsing di query DCQL alla convalida crittografica

Andrea Masiero
Settembre 2026



Università degli Studi di Padova

Indice degli argomenti

1 L'azienda

2 Il progetto

3 La soluzione

4 Risultati

5 Conclusioni

L'azienda

monokee

PURE IDENTITY.

- **Piattaforma avanzata IAM** (Identity and Access Management).
- Orchestratore visivo per l'automazione di flussi complessi.
- **Contesto tecnologico:** gestione dell'identità digitale, credenziali decentralizzate ed ecosistema EUDI Wallet.

Contesto e idea

- **Il modulo:** progettazione e sviluppo da zero di `monokee-relyingparty-core`.
- **L'idea:** implementare un *Relying Party* (Verifier) capace di richiedere, ricevere e validare *Verifiable Credentials*.
- **Nel contesto aziendale:** abilitare l'autenticazione tramite *wallet* digitali integrando il protocollo *OpenID4VP* nell'infrastruttura IAM.

Tecnologie



TypeScript



Node.js



Docker



Express.js



MongoDB



Redis

Architettura bottom-up

Sviluppo incrementale articolato in quattro layer:

1. **Modellazione dei dati:** entità di dominio (`ClientModel`, `SessionModel`) ed enumeratori crittografici.
2. **Layer di accesso ai dati:** *repository* su **Redis** (sessioni) e **MongoDB** (configurazioni).
3. **Layer di logica applicativa:** servizi di inizializzazione, elaborazione risposta e validazione crittografica.
4. **Layer di presentazione:** *route* Express e interfacce REST.

Sicurezza by design

Come garantire la solidità di un sistema crittografico?

- **Verifica statica:** type checking rigoroso (`alwaysStrict: true`) per vincolare staticamente gli algoritmi crittografici supportati.
- **Misure difensive:** validazione preventiva e isolamento *URL-safe* degli input per evitare manipolazioni e *injection*.
- **Audit automatico:** controllo continuo delle vulnerabilità nelle dipendenze eseguito ad ogni riavvio (`yarn audit`).

Validazione Crittografica

OpenID Federation (Trust Chain)

Navigazione ricorsiva tramite visita in profondità (DFS) con *cycle detection* per validare l'intera catena di fiducia.

SD-JWT (Selective Disclosure)

Parsifica del *token*, controllo della firma dell'*Issuer*, validazione degli *hash* (disclosures) e verifica del *Key Binding*.

Query DCQL

Parsing strutturato e validazione semantica avanzata delle richieste formali espresse in *Digital Credentials Query Language*.

Affidabilità

Come evitare inconsistenze di stato per le sessioni utente?

- **Stato su Redis:** ogni sessione ha un *TTL* automatico e le chiavi asimmetriche (Forward Secrecy) vengono distrutte atomicamente post-utilizzo.
- **Scalabilità orizzontale:** assenza di stato in memoria, i server possono essere replicati nativamente dietro a un load balancer.
- **Multi-tenancy nativa:** isolamento per dominio garantito sia a livello applicativo che sui database tramite indici composti.

Validazione Formale

- **Conformance Test:** superamento dell'intera suite di certificazione ufficiale fornita dalla **OpenID Foundation**.
- **Profilo Verificato:** superamento completo del profilo *OID4VP Verifier*.
- **Obiettivo:** garanzia di interoperabilità assoluta con qualsiasi *Wallet* certificato europeo presente sul mercato.

Obiettivi Raggiunti

Requisito	Stato
RF-01: Inizializzazione sessione OID4VP	Soddisfatto
RF-05: Supporto a 6 schemi *Client ID*	Soddisfatto
RF-06: Verifica crittografica SD-JWT	Soddisfatto
RF-07: Risoluzione *Trust Chain*	Soddisfatto
RF-09: Validazione DCQL completa	Soddisfatto
RF-10: Gestione chiavi effimere JWE	Soddisfatto

- **Completamento:** 10/10 Requisiti Funzionali soddisfatti (100%).

Retrospettiva

- **Valore aggiunto architetturale:**
  - Sicurezza crittografica *end-to-end*.
  - Alta disponibilità ed estrema flessibilità.

- **Utilità reale:** realizzato un microservizio *backend* completo, testato, affidabile e **production-ready**, pronto per l'integrazione nell'ecosistema *enterprise* di Monokee.

Grazie per l'attenzione